

RACF Security Fundamentals





IBM Z AND Z/OS SECURITY FEATURES

Security on z/OS systems is complicated and, one could say, messy. Multiple different z/OS components and subsystems play a role in security, and their configuration settings and functions can conflict with each other and even conflict internally within the same product.

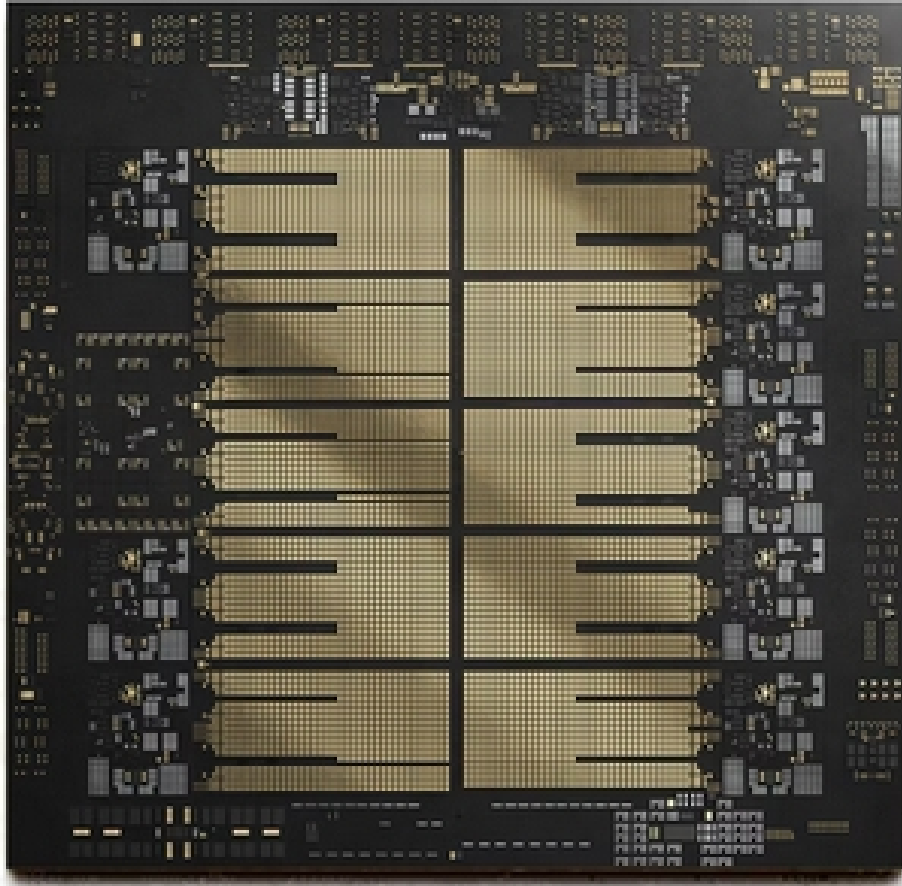
This training will not cover all that in depth.

Security at your company will be more thoughtfully designed, comprehensively implemented, and professionally managed than the simple setup you'll see in the lab environment.

Don't expect to hit the ground running in a security administration role. Do expect to gain a general, conceptual understanding on which to build.



IBM Z HARDWARE-BASED SECURITY FEATURES



The z17 uses Telum II processor chips (left). Each unit has 32 processor cores grouped into 4 cross-connected "coreclusters." The increased power of these chips means a z17 equipped with 40 of them far exceeds the capacity of a z16 with 200 Telum I processors.

Telum II is touted as "AI-ready" because the units include IBM's Spyre AI Accelerator, which is optimized to support inference processing.

From a security standpoint, the interesting thing is that the devices also feature built-in cryptographic support. The claim is that the cryptographic support is quantum-safe, meaning methods of hacking based on quantum computing should have difficulty breaking encryption.

IBM Z HARDWARE-BASED SECURITY FEATURES

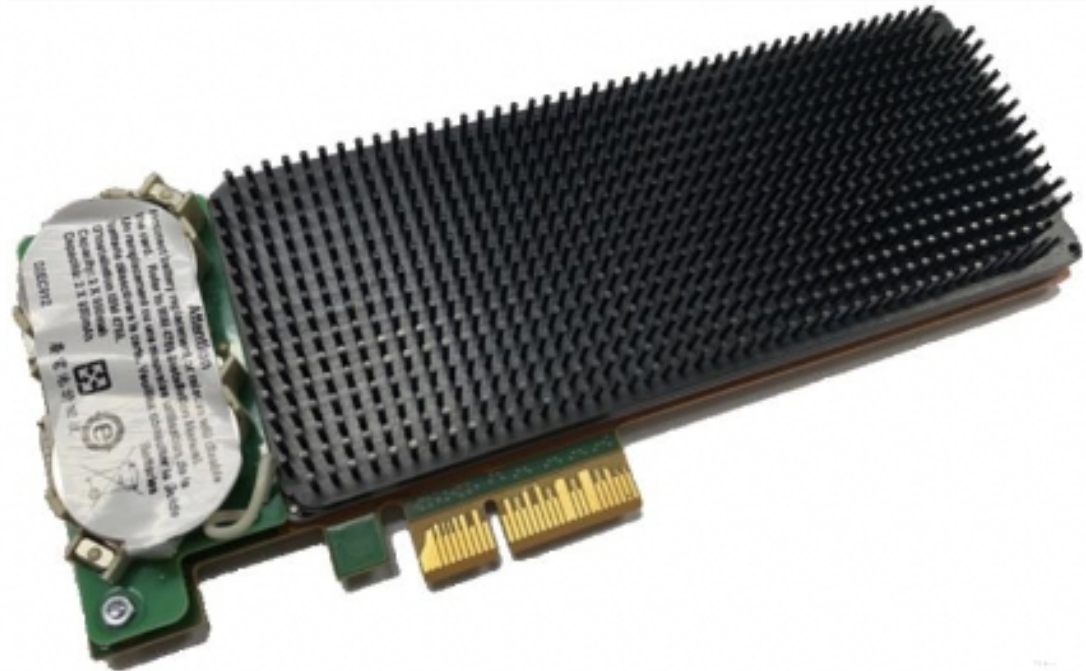
The Crypto Express is a Hardware Security Module (HSM) that supports too many cryptographic features to list here. It's tamper-proof in multiple ways.

It has an embedded certificate with public/private keys it generates in the final stage of manufacture and stores internally. Firmware updates are verified genuine.

It detects software attacks and protects the system accordingly. It supports over 300 cryptographic algorithms.

It detects physical tampering of various kinds, including removal of the device from the frame, physically drilling or cutting into the device, and changes in temperature, humidity, or barometric pressure beyond defined limits. It has three modes of operation: (1) Common Cryptographic Architecture (CCA) for financial transaction processing; (2) PKCS 11 for internet business applications; and (3) clear key accelerator mode to offload of compute-intensive operations.

When it detects tampering of any kind, it commits suicide. Keys and other data are destroyed and the unit is rendered permanently inoperable.



IBM Z/OS SOFTWARE AND SYSTEM SECURITY

z/OS Security Server

RACF and other functions

DFSMS (+ RACF)

Data set security

SMF

Logging and auditing

TSO/E

Integration with RACF

AT-TLS

TN3270, TCP, RACF

TCP/IP Security

Built-in features of stack

APF + Storage Key

Authorized Program Facility

MFA/SSO Integration

IBM MFA, Kerberos, LDAP

IBM MFA for z/OS

Token-based auth, OTP

USS / POSIX

UID/GID mapping, file mode

DB2

Internal security

Subsystem Integr.

CICS, IMS, others

IBM Z/OS NETWORK SECURITY

TCP/IP

- TLS (Transport-Layer Security)
- Intrusion Detection Services (IDS)
- Port control
- SAF

TN3270

- TLS (Transport-Layer Security)
- LU choice
- Application selection
- Client behavior

SNA (legacy)

- Used for app-to-app communication
- Not used for public network access

IBM Z/OS STORAGE KEY PROTECTION



The chances of malicious code finding its way into a z/OS address space are vanishingly small, but should it happen the most ancient of software-based security features is still in place: Storage key protection.

You learned about this earlier in the program. It's a mechanism to prevent non-privileged code from modifying memory locations owned by privileged code.

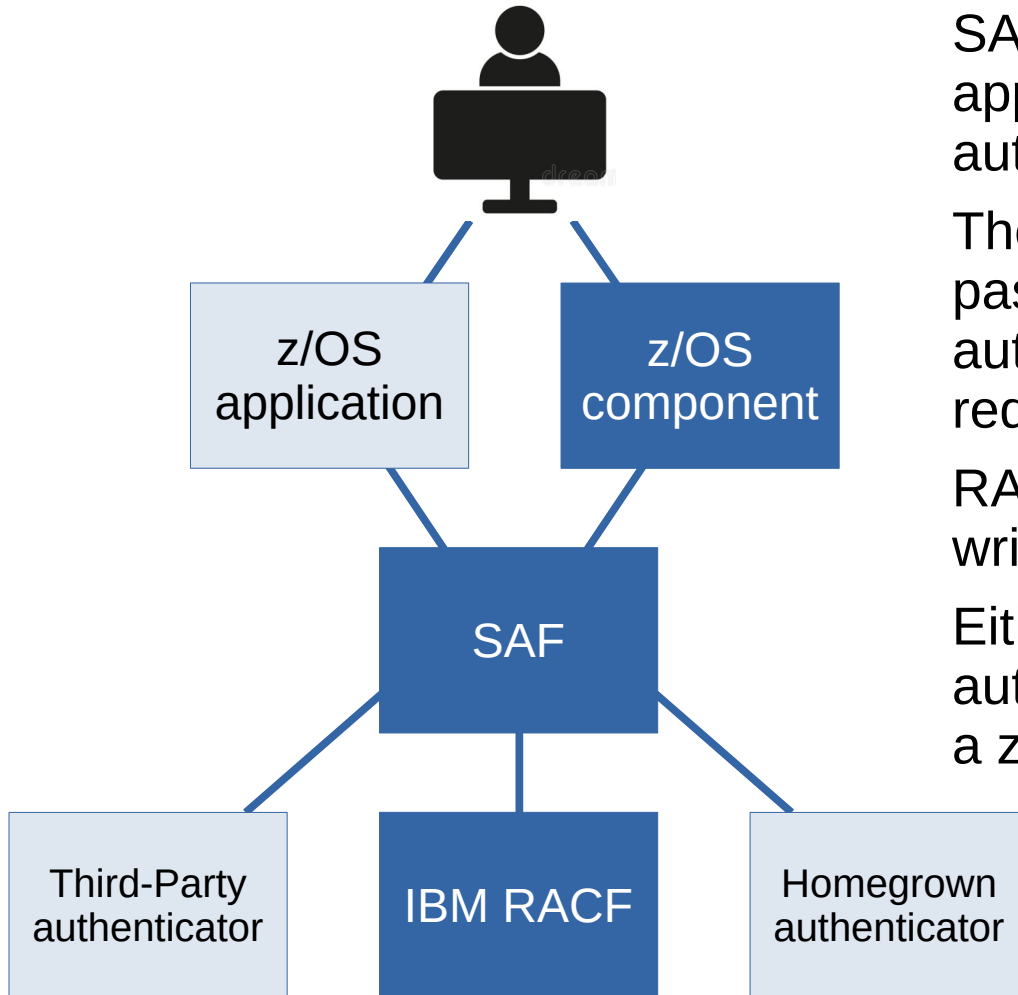
IBM Z/OS SECURITY SERVER

z/OS Security Server is a set of z/OS facilities that collectively provide software-based security for IBM z/OS systems.

People often refer to all of this as "RACF," although RACF itself is only one of several components of z/OS Security Server.

- RACF – Resource Access Control Facility
- DCE Security Server – OSF DCE 1.1 server
- LDAP – Lightweight Directory Access Protocol
- z/OS Firewall Technologies – IPV4 firewall and VPN support
- NAS – Network Authorization Service for z/OS
- EIM – Enterprise Identity Mapping
- PKI Services – public keys and certificate authority

Z/OS SAF – SYSTEM AUTHORIZATION FACILITY



SAF provides a central point for z/OS applications and system components to request authorization services.

The main component of SAF, the SAF Router, passes authorization requests to one or more authorization systems when an application requests access to a resource.

RACF, several third-party products, and user-written authorization code can interact with SAF.

Either RACF or at least one non-IBM authorization product is strongly recommended in a z/OS environment.

FUNCTIONS OF RACF

RACF (Resource Access Control Facility) controls access to resources based on user groups defined with userids that have the same privileges. When a user (or application running under a userid) attempts to access a resource, RACF checks the privileges defined for the userid's group against the type of access they are attempting for the given resource. RACF performs these functions:



- User identification
- User verification
- Authorization checking
- Logging and reporting
- Multilevel security

RACF USER IDENTIFICATION

RACF identifies the user when they sign on to the z/OS system. It compares the userid they enter with those in its database. If the userid is not known to RACF, the sign on process is interrupted at that point.

After the user has signed on, RACF uses their userid to check their privileges for each resource they attempt to access.



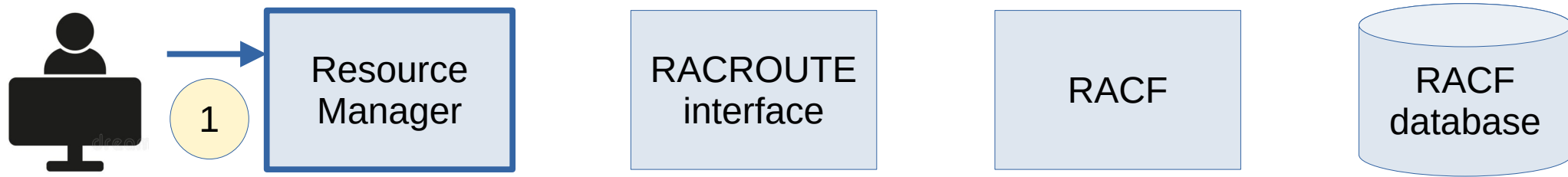
RACF USER VERIFICATION



When you define a user to RACF you assign an initial password, which they must change the first time they sign on.

RACF keeps the password in encrypted form and uses it to verify the user during the sign on process.

RACF AUTHORIZATION CHECKING



User attempts to take an action on a resource.

Examples:

User submits a batch job in which an application program issues a DB2 'EXEC SQL SELECT . . .' command.

In this case, the Resource Manager is DB2 and the resource is a DB2 table.

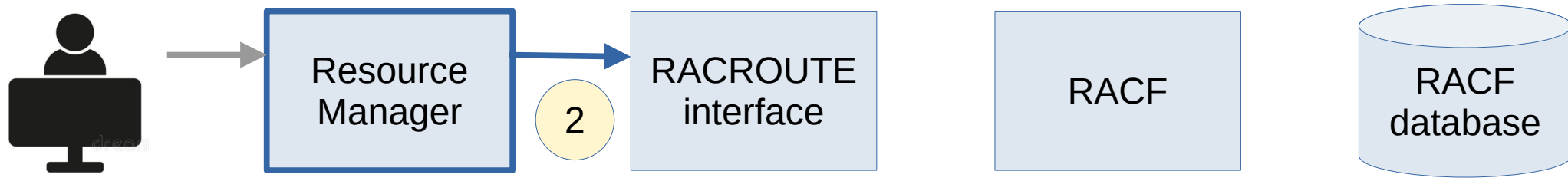
User submits a TSO/ISPF form to allocate a data set.

In this case, the Resource Manager is TSO/E and the resource is the data set.

User chooses an action on a CICS application screen that causes the application to issue a CICS 'EXEC CICS WRITE' command to a VSAM KSDS.

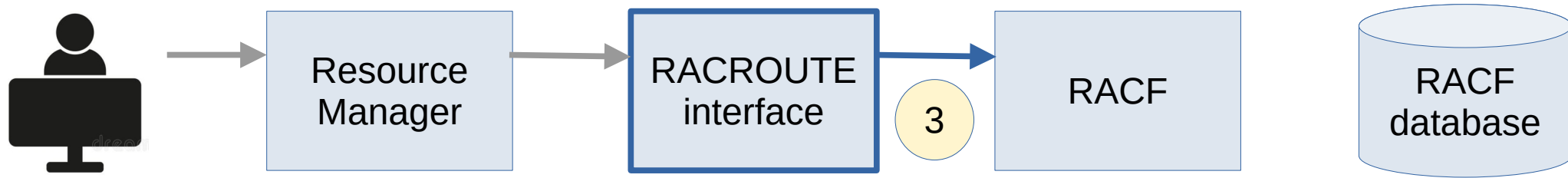
In this case, the Resource Manager is VSAM and the resource is the KSDS.

RACF AUTHORIZATION CHECKING



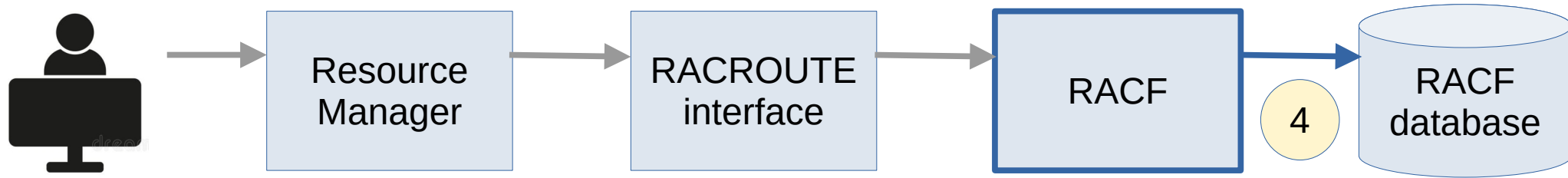
Resource Manager queries RACF via the RACROUTE interface to see whether the user is authorized to take the requested action on the resource.

RACF AUTHORIZATION CHECKING



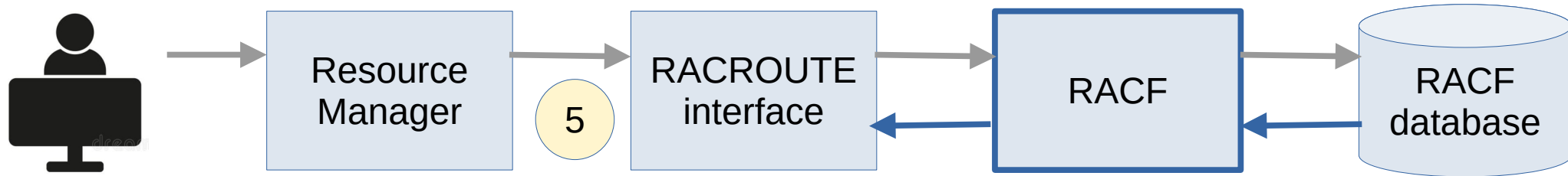
RACROUTE passes the request along to RACF or to whatever authorization product is installed.

RACF AUTHORIZATION CHECKING



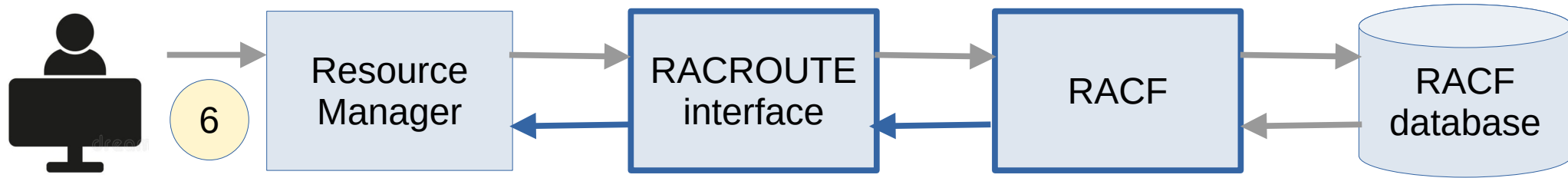
RACF looks up the information in its database (might be in memory).

RACF AUTHORIZATION CHECKING



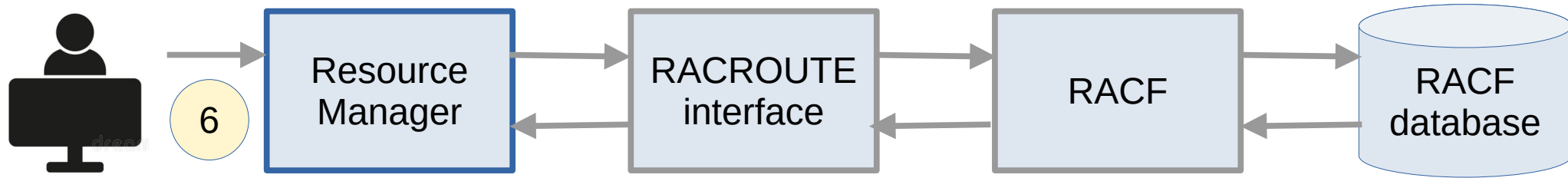
RACF returns the Yes/No result to the Resource Manager

RACF AUTHORIZATION CHECKING



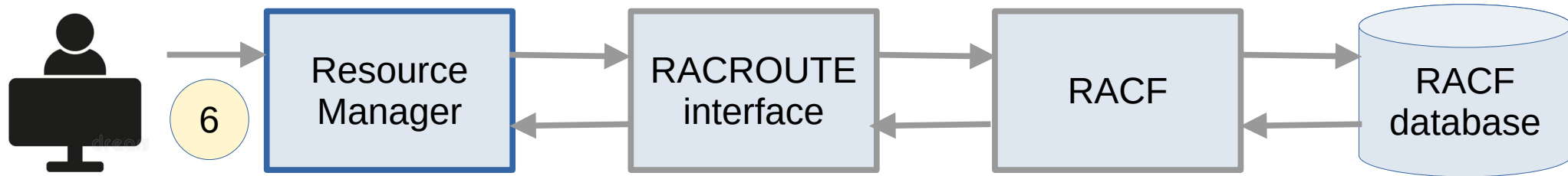
RACF returns the Yes/No result to the Resource Manager

RACF AUTHORIZATION CHECKING



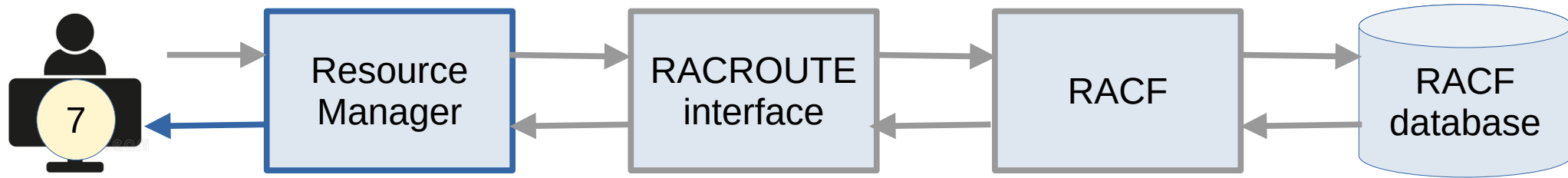
RACF returns the Yes/No result to the Resource Manager

RACF AUTHORIZATION CHECKING



Resource Manager carries out the requested action if the user is authorized, otherwise notifies the user or the application the user is using that the action is not authorized.

RACF AUTHORIZATION CHECKING



Resource Manager or application informs user of result.

RACF LOGGING AND REPORTING

RACF uses SMF to log unauthorized attempts to

- access RACF-protected resources
- issue RACF commands
- alter RACF profiles

Sends notifications to the security console and optionally to a designated TSO account

Optionally keeps statistics such as how many times a user enters the system and how many times a given user accesses a particular resource



RACF AND MULTILEVEL SECURITY

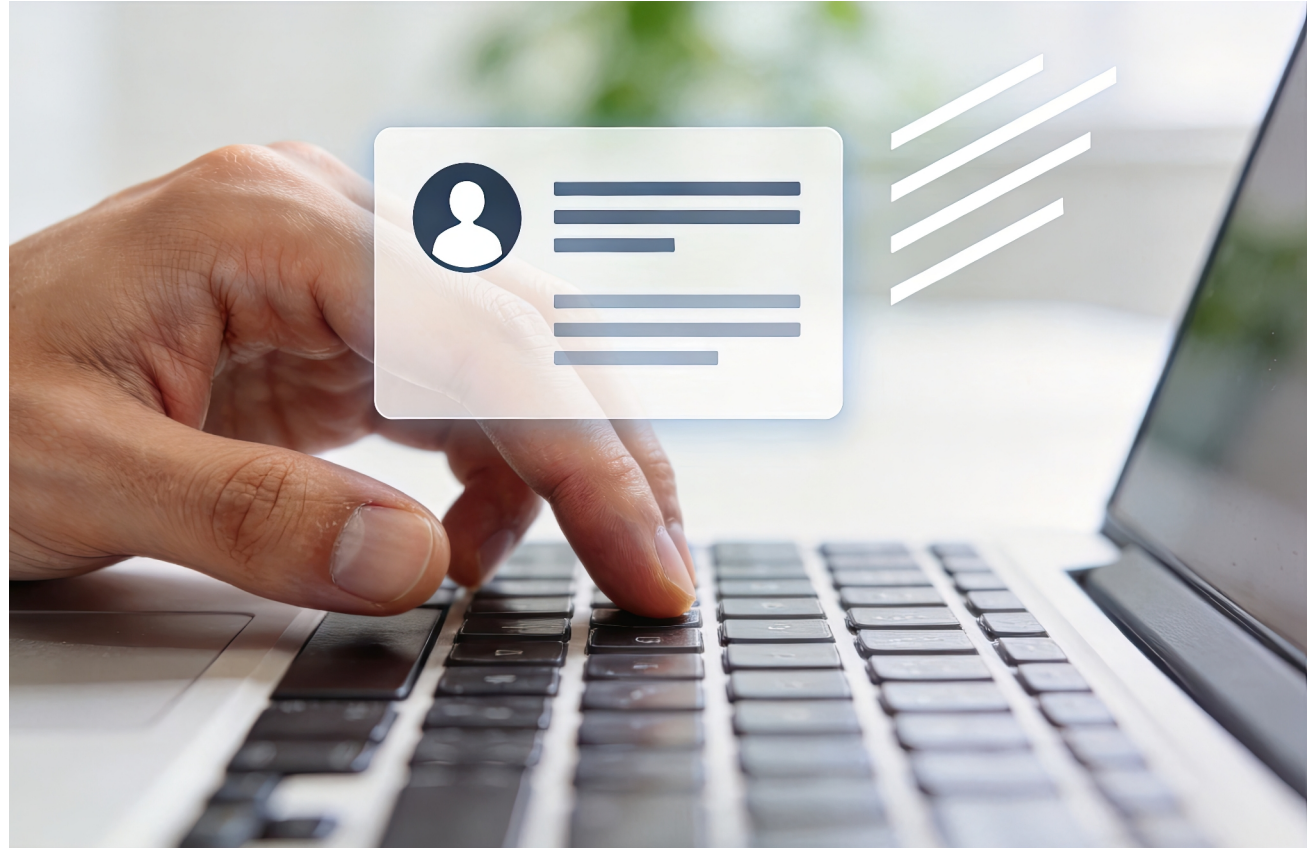
Multilevel Security is a set of criteria defined by the United States Department of Defense that defense contractors are expected to meet. RACF plays a role in this. Complete and certified support for multilevel security is not in place as of the time of writing (2026).



RACF USER PROFILES

Each authorized user of the system needs a User Profile in the RACF database.

The profile contains general information about the user, such as the userid, creation date, revoke date, any limitations on days of the week and times of day when the user can sign on to the system, their default group, and so on.



RACF USER PROFILES – USER IDS / NAMES

The rules for forming a RACF userid are the same as for other names in the z/OS environment that are limited to a maximum of 8 characters in length.

The 8 character length limitation is a requirement of the Brain-in-a-Jar. Just as for a program name or a job name or any other 8-character name on this system, the rules are:

Length of the userid can be between 1 and 8 characters.

Valid characters include the uppercase letters A-Z, numerals 0-9, and what IBM calls "national characters", #, \$, and @.

An additional consideration for the national characters is that devices outside the United States may not display them as expected. IBM recommends using whatever characters correspond to these hexadecimal codes in non-US locales:

- # x'7B'
- \$ x'5B'
- @ x'7C'

The first character of the userid can't be a numeral.

RACF USER PROFILES – USER IDS / NAMES

The rules for forming a RACF userid are the same as for other names in the z/OS environment that are limited to a maximum of 8 characters in length.

The 8 character program name rules are:

Length of the

Valid character "national character"

An additional States may not correspond to

- # x'7B'
- \$ x'5B'
- @ x'7C'

The first character of the userid can't be a numeral.

Oldtimer Nugget

There are situations when we append one or two characters to the end of a userid, e.g. for a job name. For that reason, it's best to avoid defining userids that are 8 characters long.

Most organizations I've seen use 6 characters, and some use 7.



for a
e rules

M calls

the United
characters

RACF USER PROFILES - SEGMENTS

User Profile information is organized in *segments*. Segments contain *fields*.

Authority to alter the information can be defined at the segment level and/ or at the individual field level.

Only the Base Segment is mandatory. There are several application-specific segments that are rarely used.

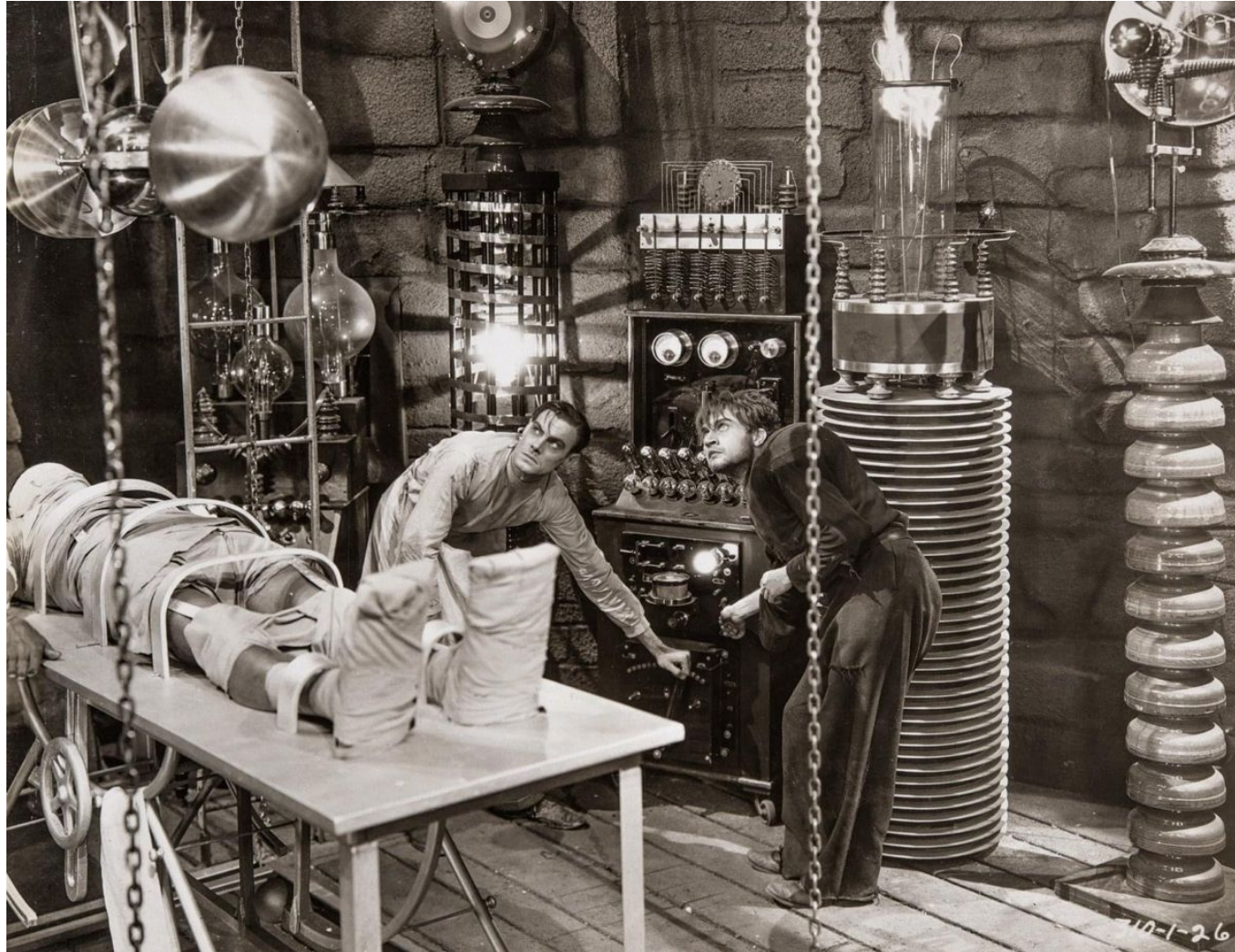
The following are the most common segments.

Base Segment	General information about the user and their system access
CICS Segment	Information used when the user signs on to CICS
DFP Segment	Defaults DFP uses for management of user data sets
OMVS Segment	USS user information
TSO Segment	Information used for the user's TSO sessions

It shows the basic information about the userid as well as its group memberships.

28

LAB Z/OS 28: DISPLAY YOUR OWN RACF INFO



RACF USER PROFILES - ADDUSER

The exact command, and the place in TSO or ISPF where you enter it, depend on what optional software is installed on z/OS and how RACF and TSO have been configured.

On our lab system, we use the TSO READY prompt to enter RACF commands. Support for RACF ISPF panels is not available on that system. In that environment, there's no need to prefix the commands with "RACF" or any other special characters. A basic command to create a new user profile looks like this:

```
ADDUSER userid PASSWORD(something)
```

RACF USER PROFILES – NAMING CONVENTION

Neither z/OS nor RACF nor any other software requires userids to follow any particular rules beyond the basic rules for 8-character names on MVS. For our lab work, we'd like to use a simple naming convention to help us keep everything straight.

The Platform Engineer userids will have the form, PLAT nn , where nn is a number – 01, 02, 03, etc.

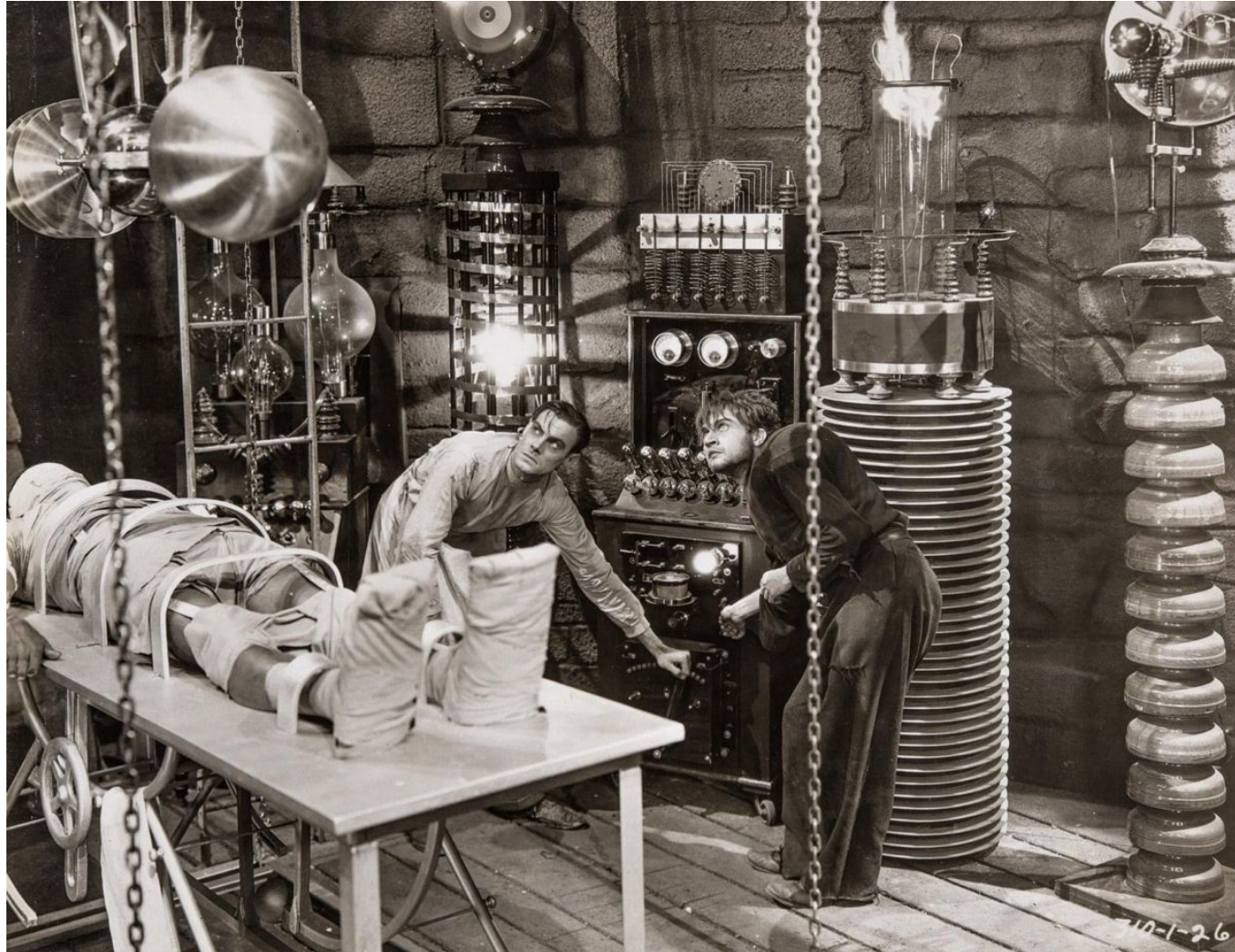
The "developer" userids that you create will have the form, DEV $nnmm$, where nn is the number in your own userid, and mm is a sequential number like 01, 02, 03.

The OWNER is always going to be userid IBMUSER. (That won't be the case in Real Life®.)

So, if you wanted to define a "developer" to RACF, and your RACF userid is PLAT04, you might name the developer DEV0401, like this:

```
ADDUSER DEV0401 PASSWORD (NEWPASS) OWNER (IBMUSER)
```


LAB Z/OS 29: CREATE A NEW USER PROFILE



RACF USER PROFILES – ADDING TSO ACCESS

Okay, that wasn't entirely fair. Your new user can't access TSO. You have to add a few things to their profile to enable that. Here's a minimal set of definitions. If we do a LISTUSER for the userid, we get something like this.

LISTUSER DEV0101 TSO

We're asking to see the information from the base segment and the TSO segment of the profile.

But there isn't a TSO segment. We didn't define one. By default, that means no TSO access for this userid.

```
listuser dev0101 tso
USER=DEV0101  NAME=UNKNOWN  OWNER=IBMUSER  CREATED=26.169
DEFAULT-GROUP=PLATENG  PASSDATE=00.000  PASS-INTERVAL= 30 PHRA
ATTRIBUTES=NONE
REVOKE DATE=NONE  RESUME DATE=NONE
LAST-ACCESS=26.169/14:17:04
CLASS AUTHORIZATIONS=NONE
NO-INSTALLATION-DATA
NO-MODEL-NAME
LOGON ALLOWED      (DAYS)              (TIME)
-----
ANYDAY              ANYTIME
GROUP=PLATENG  AUTH=USE  CONNECT-OWNER=IBMUSER  CONNEC
CONNECTS=      00  UACC=NONE  LAST-CONNECT=UNKNOWN
CONNECT ATTRIBUTES=NONE
REVOKE DATE=NONE  RESUME DATE=NONE
SECURITY-LEVEL=NONE SPECIFIED
CATEGORY-AUTHORIZATION
NONE SPECIFIED
SECURITY-LABEL=NONE SPECIFIED
NO TSO INFORMATION
READY
```

RACF USER PROFILES – ADDING TSO ACCESS

The ALTUSER command enables you to modify the contents of the user's profile. Heer's a minimal example of how to add TSO support to their profile.

```
ALTUSER DEV0401 TSO (ACCTNUM (ACCT001)  
PROC (DB13PROC)  
SIZE (2096128) )
```

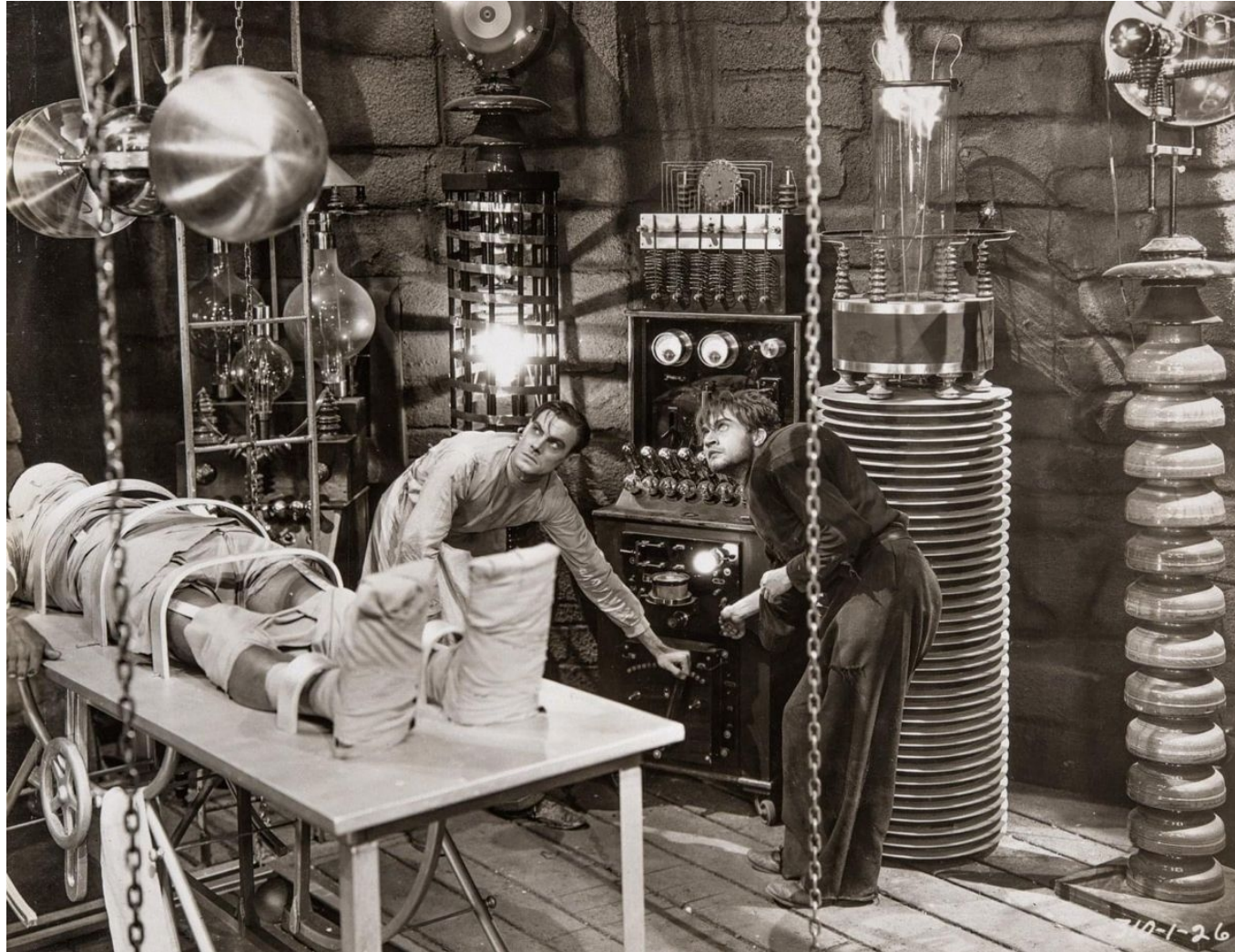
That's all one line, by the way. Don't press Enter in the middle of it.

The ACCTNUM parameter assigns an accounting category for the user's activity on the system.

The PROC parameter names a JCL PROC to be executed when the user signs on.

The SIZE parameter sets a size for working memory for the TSO session.

LAB Z/OS 30: ADD TSO ACCESS FOR THE NEW USER



RACF USER PROFILES – CHANGE INITIAL PASSWORD

That's better. The new user can sign on to TSO. But what's going on with those password forms?

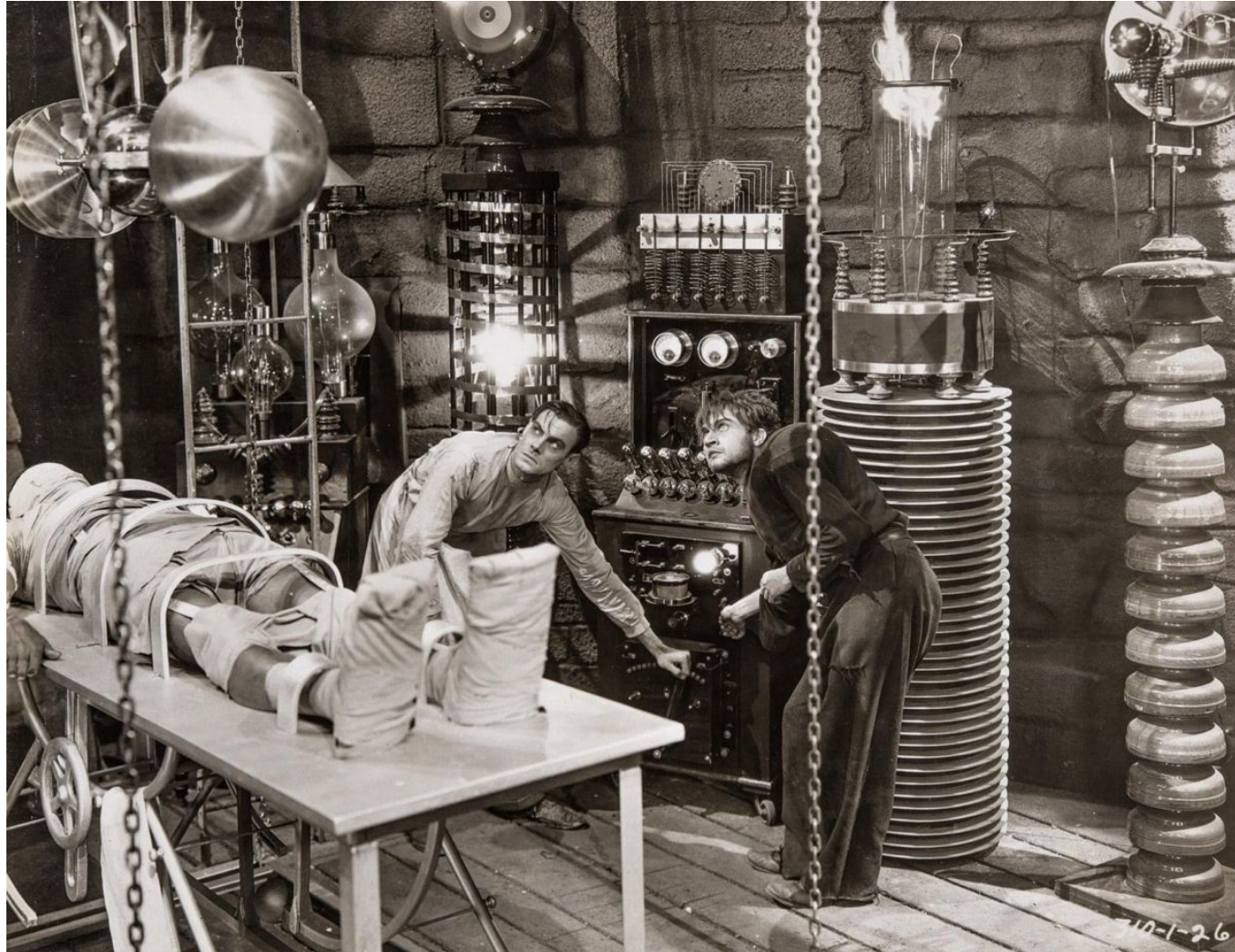
The first time a user signs on using a default password set by a RACF administrator, they have to change the password. IT isn't necessarily intuitive, but what they must do is enter a new password and press Enter. Then they'll see the same form again. The system wants them to enter the same new password again, to confirm it. The next time they press Enter, they'll get in.

But now there's another problem! When they get past the "change password" form, TSO tells them they aren't authorized for ACCTNUM ACCT001. We type spaces over it and press Enter, and now they aren't authorized for PROC DB13PROC. How can we remove those from the profile so they won't have to deal with it during sign-on?

ALTUSER DEV0401 TSO (NOACCTNUM NOPROC)

To get rid of a value in a user profile, specify the parameter name prefixed with the word NO.

LAB Z/OS 31: REMOVE VALUES FROM A USER PROFILE



RACF USER PROFILES – RUN COMMAND

```
ICH70001I DEV0101  LAST ACCESS AT 14:49:45 ON THURSDAY, JUNE 18, 2026  
DEV0101 LOGON IN PROGRESS AT 14:58:37 ON JUNE 18, 2026  
NO BROADCAST MESSAGES  
READY
```

Finally, they're in! That's much better. But if they're working as an application developer, they'll want to use ISPF nearly all the time. Their first act after signing on to TSO will be to start ISPF. We can save them the trouble by defining a command to be executed automatically upon successful sign on.

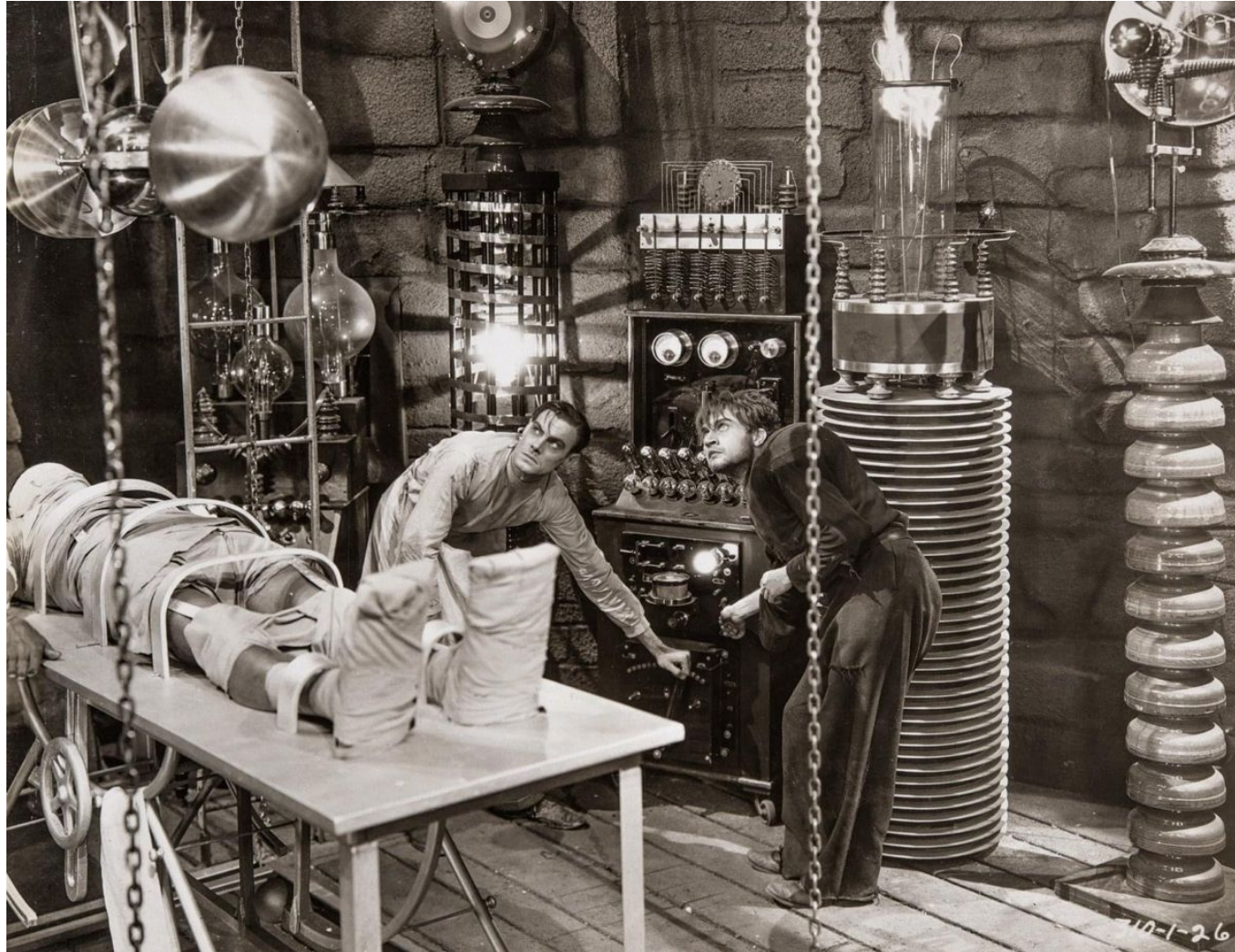
ALTUSER DEV0401 TSO (COMMAND (ISPF))

↑
segment

↑
field

↑
value

LAB Z/OS 32: SPECIFY AN INITIAL COMMAND



RACF USER PROFILES – RUN COMMAND

```
Menu  Utilities  Compilers  Options  Status  Help
-----
ISPSP Primary Option Menu

0  Settings
1  View
2  Edit
3  Utilities
4  Foreground
5  Batch
6  Command
7  Dialog Test
9  IBM Products
10 SCLM
11 Workplace
12 z/OS System
13 z/OS User

Enter X to Terminate using log/list defaults
```

Seeing the ISPF Primary Option Menu is as refreshing as a tall, cool glass of water on a hot day.

```
User ID . : DEV0101
Time. . . : 15:04
Terminal. : 3278
Screen. . : 1
Language. : ENGLISH
Appl ID . : ISR
TSO logon : MATPROC
TSO prefix: DEV0101
System ID : VS01
MVS acct. : **NONE**
Release . : ISPF 8.1
```

RACF GROUPS

Typical RACF approach:

- Groups have permissions
- Users belong to groups

Permissions are usually set at the group level, not at the individual user level. That isn't enforced, and organizations have to plan carefully to avoid creating conflicts in RACF settings.

Groups can exist within groups, resulting in a hierarchy of groups.

Before we can do more with our new user profile, we need to define a group for it to belong to.



RACF USER PROFILES – ADDING A GROUP

If you used the userid you just created to access USS (Unix System Services), you'd have the same issue as you did when you first tried to access TSO. We have to add a OMVS segment to the RACF user profile to enable access to USS.

```
ADDGROUP DEV OWNER(IBMUSER) GID(401)  
CONNECT DEV0401 GROUP(DEV)  
ALTUSER DEV0401 DFLTGRP(DEV)
```

That's three separate commands.

ADDGROUP creates the RACF group named DEV.

GID is part of POSIX security under USS. It's matched with UIDs.

HOME specifies the home directory for the user. PROGRAM specifies the default shell.

DFLTGRP specifies the default group to which the user belongs.

RACF USER PROFILES – ADDING USS ACCESS

If you used the userid you just created to access USS (Unix System Services), you'd have the same issue as you did when you first tried to access TSO. We have to add a OMVS segment to the RACF user profile to enable access to USS.

```
ALTUSER DEV0401 OMVS (HOME ( ' /u/dev0401 ' )  
                        PROGRAM ( ' /bin/sh ' )  
                        UID (401) )
```

That's all one line.

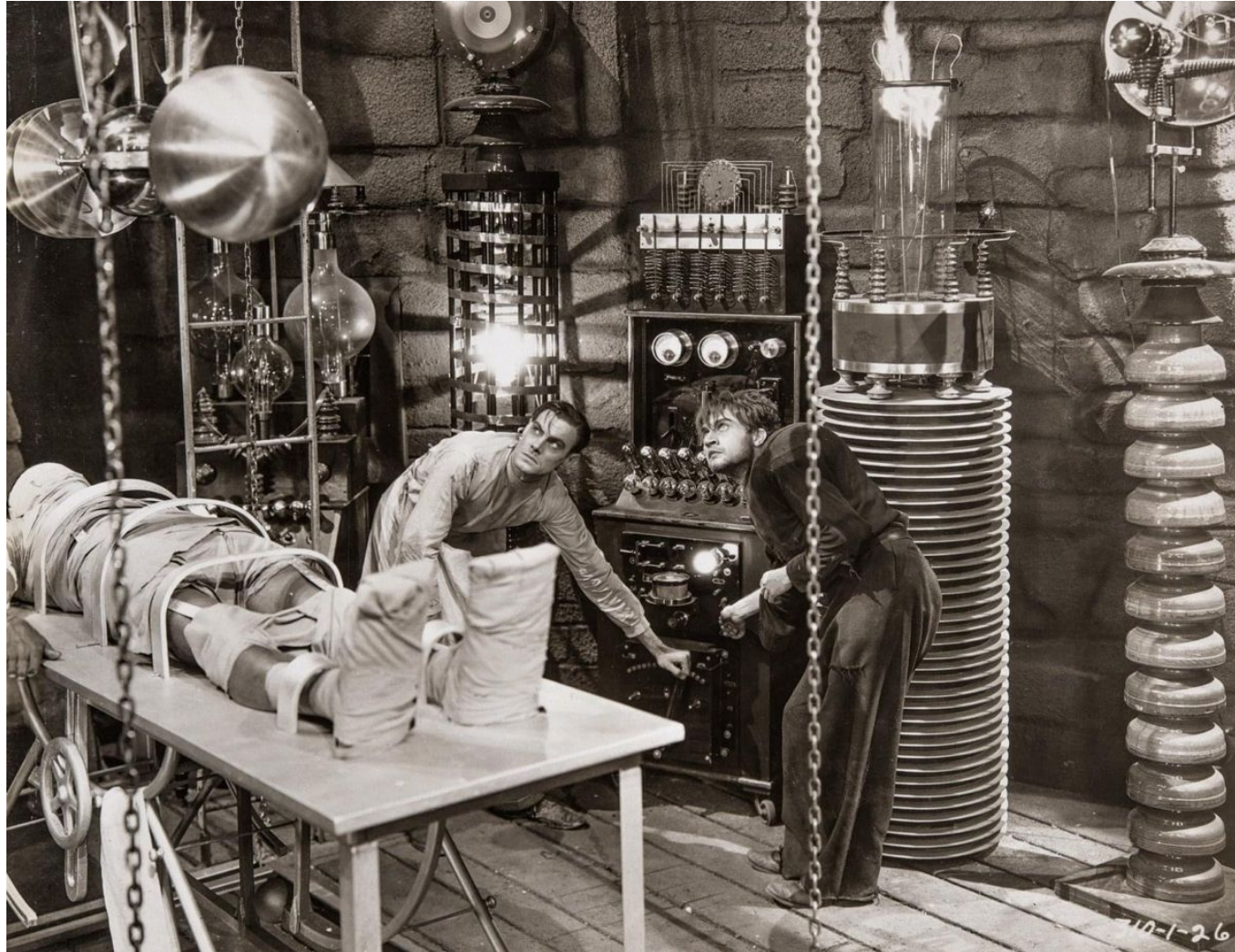
You can define the OMVS segment on the ADDUSER command or wait until later and define it with ALTUSER, as in this example.

HOME specifies the home directory for the user. PROGRAM specifies the default shell.

UID is the User ID the system will match against the Group ID (GID) in the user's default RACF group. That's part of POSIX-style security under USS.

DFLTGRP specifies the default group to which the user belongs.

LAB Z/OS 33: CREATE GROUP, ENABLE USS ACCESS



RACF ACCESS LEVELS

ALTER – You can do anything with the resource.

CONTROL – Read, Write, Execute, and set ACL. Can't modify the ACL.

UPDATE – View and Edit the resource but not administer it.

READ – View the resource but not modify it.

NONE – Prohibited from accessing the resource.



WHAT YOU KNOW AND WHAT YOU CAN DO

- You have basic knowledge of RACF

WHAT'S NEXT

- Job Entry Subsystem